

Digital colleague

Axel Ilenre

24160873

EU AI Act Compliance & AI Governance Risk Assessment

Prepared by: Dr. Axel, AI Governance Strategist

Focus: High-Risk AI Credit Scoring (based on *Evaluating Fairness Metrics & Axel Ilenre's Compliance Framework*)

Core Philosophy: "Technology creates possibilities, but human judgment creates value."

1. High-Risk System Classification (Annex III, Point 5(b))

- **Finding:** The research paper evaluates classifiers using the *German Credit Dataset* to perform binary classification on creditworthiness ("Good" vs. "Bad" Risk).
- **EU AI Act Mandate:** Under Annex III, Point 5(b), AI systems intended to be used to evaluate the creditworthiness of natural persons or establish their credit score are classified as **High-Risk AI Systems**.
- **Governance Risk:** Deploying such a system triggers mandatory compliance with Articles 8-15 of the EU AI Act. This requires establishing a continuous risk management system, detailed logging, thorough technical documentation, and registration in the EU database before deployment.

2. Data Governance & Bias Auditing Shortfalls (Article 10)

- **Finding:** The paper highlights that demographic fairness metrics (Statistical Parity Difference and Disparate Impact) are independent of actual target values and rely solely on model predictions.

3. Accuracy, Robustness, and Generalizability Failures (Article 15)

- **Finding:** The experiments reveal extreme performance disparities among classifiers. The *Gaussian Process Classifier (GPC)* was equivalent to a random guess (AUC of 0.5) and was highly unfair. Conversely, the *Gaussian Naïve Bayesian (GNB)* achieved a perfect AUC of 1.0.
- **EU AI Act Mandate:** Article 15 mandates that high-risk AI systems must achieve appropriate levels of accuracy, robustness, and cybersecurity throughout their lifecycle.
- **Governance Risk:** Utilizing an inaccurate classifier (like GPC) violates Article 15 and leads to immediate operational failure. On the other hand, the GNB's perfect 1.0 AUC strongly suggests overfitting or data leakage on the limited credit dataset. Deploying such a model in a live environment is a major robustness risk, as it will likely fail to generalize, leading to unexpected, discriminatory credit denials in production and substantial legal liability.

4. Privacy Violations in Bias Mitigation (Article 10(5) vs. GDPR Article 9)

- **Finding:** The paper demonstrates that the *Minimax Fairness Criterion* successfully minimizes maximum group error and reduces discrepancies between protected groups. However, executing this game-theoretic mitigation requires processing sensitive data (Age, Sex).
- **EU AI Act & GDPR Mandate:** Under GDPR Article 9, processing special category data (including sex/gender) is prohibited. However, Article 10(5) of the EU AI Act permits a narrow, supervised exception allowing the processing of sensitive personal data solely for bias detection and correction in high-risk AI systems.
- **Governance Risk:** Implementing minimax group fairness optimization without a strict compliance boundary, data

3. Data Minimization (GDPR Article 5(1)(c)) vs. Fairness Auditing Requirements

- **The Intersection:** The GDPR principle of *Data Minimization* dictates that personal data must be "adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed."
- **The Reality in the Research Brief:** To calculate demographic metrics (Statistical Parity Difference, Disparate Impact) or optimize models using the *Minimax Fairness Criterion*, the system *must* actively ingest and process protected sensitive attributes like **Age** and **Sex**.
- **The Governance Challenge:**
 - This creates a fundamental paradox: **To prove a model is not discriminating based on gender or age (Transparency), you must process data on gender and age (violating Data Minimization).**
 - **The Resolution:** To maintain transparency while complying with GDPR, organisations must implement strict data segregation. Sensitive attributes must be completely stripped from the primary model training pipeline, pseudonymised, and stored in a separate, highly secure audit environment used exclusively by the governance team to calculate fairness metrics and minimax weight adjustments.

4. Systemic Accountability and Auditability (GDPR Article 5(2))

- **The Intersection:** The GDPR *Accountability Principle* requires organizations to be able to actively demonstrate compliance.
- **The Reality in the Research Brief:** Our research brief shows that demographic parity metrics (like SPD and DI) are weak transparency mechanisms because they are independent of target values and only look at predictions,

create a summary report with all work done for stakeholders

+ Thought: Drafting The Summary Report · 3.1s

Greetings. I am Rapha, your AI Governance Strategist.

This summary report consolidates our analysis of AI governance risks, ethical challenges, regulatory best practices, and the intersection of GDPR and AI model transparency, all derived from the provided documents. Our focus has been on ensuring compliance with the **EU AI Act** and **GDPR**, particularly for high-risk AI systems in areas like credit scoring and hiring.

1. Documents Analyzed

The insights presented are based on the thorough review of the following documents:

- **FairnessMetricsBiasWorkshopCameraReady-v1.docx**: A research paper on evaluating fairness metrics, specifically using the German Credit Dataset.

Build · Gemini 2.5 Flash Google · high

A. EU AI Act Compliance & AI Governance Risks

- **High-Risk System Classification**: AI systems for credit scoring (as per the research paper) and AI-based hiring (implied by the compliance context) are unequivocally classified as **High-Risk AI Systems** under Annex III of the EU AI Act. This triggers stringent obligations for risk management, technical documentation, human oversight, and data governance.
- **Data Governance & Bias Auditing Shortfalls (Article 10)**: A sole reliance on prediction-based demographic fairness metrics (Statistical Parity Difference, Disparate Impact) is insufficient. These metrics cannot identify inherent biases within training data, directly contravening Article 10's data governance requirements.
- **Accuracy, Robustness, and Generalizability Failures (Article 15)**: The research highlighted models (e.g., Gaussian Process Classifier) with poor accuracy, failing Article 15 requirements. Conversely, seemingly perfect models (e.g., Gaussian Naïve Bayesian) raise concerns about overfitting or data leakage, which would lead to catastrophic failures in real-world deployment and major regulatory penalties.
- **Privacy Violations in Bias Mitigation (Article 10(5) vs. GDPR Article 9)**: While the EU AI Act permits limited processing of sensitive data for bias correction, such actions must strictly adhere to GDPR Article 9. Without robust data minimization, pseudonymization, and secure processing, bias mitigation efforts can lead to severe privacy violations.
- **Deficiencies in Operational Oversight (Articles 14 & 61)**: Relying on purely mathematical models for bias mitigation without continuous human oversight (Article 14) and robust risk management processes (Article 61) poses significant non-compliance risks.

Build · Gemini 2.5 Flash Google · high

36.1K (3%) · \$0.43 ctrl+p commands

Above are the result and interaction from my AI digital colleague, it analysed a few documents in my project file. My agent is a AI governance expert and ethical AI use colleague so it did some analyse and give feedbacks.

At the end it generated a report for stakeholders.